```
$ whoami
apprenti-hacker-ethique
$ cat objectifs.txt
comprendre > proteger > tester avec autorisation
$ ./progresser --jours 30
```

$ ./programme --jours 30

Hacking éthique : programme de 30 jours

De zéro à des bases solides, étape par étape, avec ton téléphone comme seul outil.

Édition française · conçue pour être suivie depuis un téléphone · 2026

Sommaire

Mode d'emploi du programme 3

Fondations 7

Comprendre les réseaux 10

Méthodologie et sécurité web 13

Systèmes, défense et suite 16

Suivi de progression 19

AVANT DE COMMENCER

Mode d'emploi du programme

Ce programme t'emmène de zéro à une base solide en hacking éthique en 30 jours, à raison d'environ **1 h à 1 h 30 par jour**. Il n'a pas pour but de faire de toi un expert en un mois — personne ne le devient aussi vite — mais de te donner les fondations, le vocabulaire, les bons réflexes et surtout **l'assurance** de continuer seul ensuite.

Il a été pensé pour être suivi **uniquement depuis un téléphone**. Tout ce qui est proposé fonctionne avec un smartphone Android, une connexion internet et un navigateur. Si un jour tu as accès à un ordinateur, tout restera valable et deviendra simplement plus confortable.

Les trois règles d'or

> **ATTENTION**
>
> **Règle n°1 — Jamais sans autorisation écrite.** Tester un système qui ne t'appartient pas, sans accord écrit de son propriétaire, est illégal dans quasiment tous les pays, même « juste pour voir », même sans rien casser. Tu t'entraîneras uniquement sur : tes propres appareils, des laboratoires conçus pour ça (TryHackMe, Hack The Box, PortSwigger, OverTheWire, picoCTF) et des cibles explicitement autorisées (comme `scanme.nmap.org` pour les scans légers).

À RETENIR

Règle n°2 — Comprendre avant de lancer. Un hacker éthique n'est pas quelqu'un qui tape des commandes copiées sur internet. C'est quelqu'un qui sait *pourquoi* une faille existe et *comment* la corriger. Chaque jour, tu dois pouvoir expliquer ce que tu as fait à quelqu'un qui n'y connaît rien.

OBJECTIF

Règle n°3 — Un peu chaque jour vaut mieux que beaucoup une fois. Ton cerveau consolide pendant le sommeil. Une heure par jour pendant 30 jours est bien plus efficace que deux week-ends de 10 heures.

Comment est construite chaque journée

Chaque jour suit le même rythme, pour que tu n'aies jamais à te demander « par quoi je commence ? ».

Bloc	Durée	Contenu
Théorie	20–30 min	Lire le chapitre correspondant du cours de 100 pages
Pratique	30–45 min	Exercice concret sur téléphone (Termux ou navigateur)
Validation	10 min	Répondre à la question du jour sans regarder ses notes
Journal	5 min	Noter 3 choses apprises + 1 question restée ouverte

Le **journal de bord** est l'outil le plus sous-estimé du débutant. Utilise une simple appli de notes. Dans 30 jours, le relire te montrera noir sur blanc tout le chemin parcouru — c'est la meilleure source d'assurance qui existe.

Ton équipement (100 % téléphone)

Outil	À quoi il sert	Coût
Termux (via F-Droid)	Un vrai terminal Linux sur Android	Gratuit
Navigateur (Chrome/Firefox)	Plateformes d'entraînement en ligne	Gratuit
TryHackMe	Parcours guidés pour débutants, machine d'attaque dans le navigateur	Gratuit (option payante)
PortSwigger Web Security Academy	Meilleure formation gratuite à la sécurité web	Gratuit
OverTheWire (Bandit)	Apprendre Linux en jouant, via SSH	Gratuit
picoCTF	Défis débutants avec terminal web intégré	Gratuit
Clavier Bluetooth (option)	Taper des commandes beaucoup plus vite	~10–20 €
Hacker's Keyboard (option)	Clavier Android avec touches Ctrl, Tab, flèches	Gratuit

ASTUCE TÉLÉPHONE

Installe Termux depuis **F-Droid** (le magasin d'applications libres) et non depuis le Play Store : la version du Play Store n'est plus mise à jour et pose des problèmes d'installation de paquets. Vérifie sur le site officiel de Termux la méthode d'installation recommandée au moment où tu lis ces lignes.

Vue d'ensemble des 30 jours

Phase	Jours	Thème	À la fin, tu sauras…
1	1 – 7	Fondations	Ce qu'est le hacking éthique, la loi, et te déplacer dans Linux
2	8 – 14	Réseaux	Comment les machines communiquent et les observer
3	15 – 22	Méthode & Web	Mener une reconnaissance et comprendre les failles web majeures
4	23 – 30	Systèmes & défense	Mots de passe, crypto, élévation de privilèges, rapport, suite du parcours

PHASE 1 · JOURS 1 À 7

Fondations

OBJECTIF

À la fin de cette semaine, tu sais expliquer ce qu'est un hacker éthique, tu connais les limites légales, tu as un terminal Linux fonctionnel sur ton téléphone et tu t'y déplaces sans stress.

Jour 1 — Qu'est-ce que le hacking éthique ?

Théorie — Cours, chapitre 1. Les différents profils (white hat, black hat, grey hat), le métier de pentesteur, les équipes Red Team / Blue Team / Purple Team, la triade **CIA** (Confidentialité, Intégrité, Disponibilité).

Pratique — Crée ton compte sur TryHackMe et sur PortSwigger Web Security Academy. Ouvre ton journal de bord et écris ta motivation : *pourquoi* veux-tu apprendre ça ?

Validation — Explique en deux phrases la différence entre un pirate et un pentesteur. (Indice : ce n'est pas la technique, c'est l'autorisation.)

Jour 2 — La loi et l'éthique

Théorie — Cours, chapitre 2. Les lois qui encadrent l'accès aux systèmes, la notion de **périmètre** (scope), les **règles d'engagement**, la divulgation responsable, les programmes de bug bounty.

Pratique — Lis la page « politique de divulgation » (souvent appelée `security.txt` ou « Responsible Disclosure ») de deux grandes entreprises. Repère : ce qui est autorisé, ce qui est interdit, comment

signaler.

Validation — Cite trois situations où tester un système serait illégal, même avec de bonnes intentions.

Jour 3 — Installer ton laboratoire de poche

Théorie — Cours, chapitre 3. Pourquoi Linux domine la sécurité, ce qu'est un terminal, un shell, un paquet.

Pratique — Installe F-Droid puis Termux. Dans Termux :

```
pkg update && pkg upgrade
pkg install nano curl openssh git python
termux-setup-storage
```

Validation — Tape `whoami`, `pwd` et `uname -a`. Explique ce que chaque commande t'a répondu.

Jour 4 — Se déplacer dans Linux

Théorie — Cours, chapitre 4 (arborescence, chemins absolus et relatifs).

Pratique — Entraîne-toi avec `ls`, `ls -la`, `cd`, `mkdir`, `touch`, `cp`, `mv`, `rm`, `cat`. Crée un dossier `labo`, avec trois sous-dossiers, et déplace des fichiers de l'un à l'autre.

Validation — Sans aide : crée `labo/notes/jour4.txt`, écris-y une phrase avec `nano`, affiche-la avec `cat`.

Jour 5 — Lire, chercher, filtrer

Théorie — Cours, chapitre 4 (suite) : `grep`, `find`, les pipes `|`, les redirections `>` et `>>`.

Pratique — Connecte-toi à OverTheWire **Bandit** depuis Termux avec `ssh` (les instructions sont sur la page du niveau 0). Termine les niveaux 0 à 3.

Validation — Explique ce que fait : `cat fichier.txt | grep motdepasse > resultat.txt`

Jour 6 — Permissions et utilisateurs

Théorie — Cours, chapitre 5. Lire `rwxr-xr--`, propriétaire / groupe / autres, `chmod`, `chown`, l'utilisateur `root`, `sudo`.

Pratique — Bandit niveaux 4 à 7. Crée un script `bonjour.sh` dans Termux, rends-le exécutable avec `chmod +x` et lance-le.

Validation — Que signifie `chmod 750 script.sh` ? Qui peut lire, écrire, exécuter ?

Jour 7 — Bilan de semaine 1

Pratique — Bandit niveaux 8 à 10 (ou rattrapage). Relis ton journal.

> **AUTO-ÉVALUATION**
>
> Peux-tu, sans notes :
>
> - Expliquer la triade CIA avec un exemple pour chaque lettre ?
> - Dire ce qu'est un périmètre d'autorisation ?
> - Créer un dossier, un fichier, le modifier, changer ses permissions ?
> - Chercher un mot dans un fichier avec `grep` ?
>
> Si tu bloques sur un point, reprends le chapitre concerné avant de continuer. Ce n'est pas un retard, c'est de la consolidation.

PHASE 2 · JOURS 8 À 14

Comprendre les réseaux

OBJECTIF

Comprendre comment deux machines communiquent, savoir lire une adresse IP, connaître les ports et protocoles courants et observer le trafic. 80 % de la sécurité repose sur ces bases.

Jour 8 — Les modèles OSI et TCP/IP

Théorie — Cours, chapitre 6. Les 7 couches OSI, les 4 couches TCP/IP, l'encapsulation.

Pratique — Sur TryHackMe, commence le module d'introduction aux réseaux (« Pre Security » / « Networking »). Dessine sur papier les couches, avec un exemple de protocole pour chacune.

Validation — À quelle couche se situe une adresse IP ? Une adresse MAC ? HTTP ?

Jour 9 — Adresses IP, masques et sous-réseaux

Théorie — Cours, chapitre 6 (adressage). IPv4, IPv6, adresses privées et publiques, notation CIDR (`/24`), NAT.

Pratique — Dans Termux : `ip addr` (ou `ifconfig`). Note ton adresse IP locale. Puis `curl ifconfig.me` pour ton adresse publique. Pourquoi sont-elles différentes ?

Validation — Combien d'adresses utilisables dans un réseau `192.168.1.0/24` ?

Jour 10 — Ports, TCP, UDP et la poignée de main

Théorie — Cours, chapitre 7. TCP vs UDP, le *three-way handshake* (SYN, SYN-ACK, ACK), les ports courants.

Pratique — Apprends par cœur le tableau des 15 ports essentiels du cours (fais-en des fiches). Fais le quiz du chapitre.

Validation — Que tourne-t-il généralement sur les ports 22, 80, 443, 3306, 3389 ?

Jour 11 — DNS, HTTP et HTTPS

Théorie — Cours, chapitre 7 (protocoles applicatifs). Résolution DNS, requêtes et réponses HTTP, codes de statut, rôle de TLS.

Pratique — Dans Termux :

```
pkg install dnsutils
nslookup wikipedia.org
curl -I https://wikipedia.org
```

Validation — Que signifient les codes 200, 301, 403, 404 et 500 ?

Jour 12 — Premier scan avec Nmap

Théorie — Cours, chapitre 8. Ce qu'est un scan, ce qu'il révèle, pourquoi il est encadré légalement.

Pratique — Installe Nmap (`pkg install nmap`) puis scanne **uniquement** la cible officielle autorisée par le projet Nmap, ou ta propre box internet :

```
nmap scanme.nmap.org
nmap -sV -p 22,80 scanme.nmap.org
```

ATTENTION

Le projet Nmap autorise des scans **légers et occasionnels** de `scanme.nmap.org`. Ne le bombarde pas, et ne scanne jamais d'autres adresses publiques.

Validation — Quelle différence entre un port *open*, *closed* et *filtered* ?

Jour 13 — Sécurité Wi-Fi et réseau local

Théorie — Cours, chapitre 9. WEP, WPA2, WPA3, les risques des réseaux publics, l'importance du mot de passe d'administration d'un routeur.

Pratique — Audite **ton propre** réseau : connecte-toi à l'interface d'administration de ton routeur. Le mot de passe par défaut est-il changé ? Le WPS est-il désactivé ? Quel chiffrement est utilisé ? Le firmware est-il à jour ?

Validation — Liste 5 mesures concrètes pour sécuriser un réseau Wi-Fi.

Jour 14 — Bilan de semaine 2

Pratique — Termine le module réseau de TryHackMe. Bandit jusqu'au niveau 12.

AUTO-ÉVALUATION

Peux-tu, sans notes :

- Expliquer ce qui se passe quand tu tapes une adresse web dans ton navigateur (DNS → TCP → TLS → HTTP) ?
- Citer 10 ports et leur service ?
- Lancer un scan Nmap légal et interpréter le résultat ?

PHASE 3 · JOURS 15 À 22

Méthodologie et sécurité web

OBJECTIF

Connaître les étapes d'un test d'intrusion, savoir mener une reconnaissance passive, et comprendre les grandes familles de failles web (OWASP Top 10) — surtout comment elles se corrigent.

Jour 15 — La méthodologie d'un pentest

Théorie — Cours, chapitre 10. Les 5 phases : reconnaissance, scan/énumération, exploitation, post-exploitation, rapport. La *kill chain*. La différence entre audit, pentest et bug bounty.

Pratique — Recopie les 5 phases dans ton journal avec, pour chacune, une question à laquelle elle répond.

Validation — Quelle phase est la plus importante pour le client ? (Réponse dans le cours.)

Jour 16 — Reconnaissance passive (OSINT)

Théorie — Cours, chapitre 11. WHOIS, DNS publics, certificats, moteurs de recherche, ce qu'on peut savoir sans jamais toucher la cible.

Pratique — Fais la reconnaissance passive **de toi-même** : cherche ton nom, ton pseudo, ton numéro. Qu'est-ce qui traîne en ligne ? Fais le ménage.

Validation — Quelle différence entre reconnaissance active et passive ? Pourquoi la passive est-elle sans risque légal pour la cible ?

Jour 17 — Comment fonctionne une application web

Théorie — Cours, chapitre 12. Client / serveur, requêtes GET et POST, cookies et sessions, le rôle de la base de données.

Pratique — Dans ton navigateur mobile, ouvre n'importe quel site et ajoute `view-source:` devant l'adresse. Repère les formulaires (`<form>`), les champs cachés, les scripts.

Validation — Où est stocké un cookie de session et pourquoi est-il précieux pour un attaquant ?

Jour 18 — L'OWASP Top 10

Théorie — Cours, chapitre 13. Les 10 grandes catégories de risques web.

Pratique — Fais des fiches : pour chaque catégorie, un exemple et une protection.

Validation — Cite 5 catégories de l'OWASP Top 10 de mémoire.

Jour 19 — Les injections (SQL)

Théorie — Cours, chapitre 14. Pourquoi une injection existe, les requêtes préparées comme solution.

Pratique — PortSwigger Academy : lis la leçon « SQL injection » et réussis le premier lab de niveau *Apprentice*.

Validation — Explique avec tes mots pourquoi une requête préparée empêche l'injection.

Jour 20 — XSS (Cross-Site Scripting)

Théorie — Cours, chapitre 14 (XSS réfléchi, stocké, DOM). L'échappement des sorties, la Content Security Policy.

Pratique — PortSwigger Academy : leçon XSS + premier lab *Apprentice*.

Validation — Quelle est la différence entre XSS réfléchi et XSS stocké ? Lequel est le plus dangereux, et pourquoi ?

Jour 21 — Authentification et contrôle d'accès

Théorie — Cours, chapitre 15. Contrôle d'accès cassé, IDOR, sessions, MFA.

Pratique — PortSwigger Academy : leçon « Access control » + un lab *Apprentice*.

Validation — Donne un exemple d'IDOR avec une URL inventée.

Jour 22 — Bilan de semaine 3

Pratique — Fais une salle TryHackMe débutant liée au web (par exemple autour de l'OWASP Top 10).

> **AUTO-ÉVALUATION**
>
> Peux-tu, sans notes :
>
> - Réciter les 5 phases d'un pentest ?
> - Expliquer SQLi, XSS et IDOR à un ami ET la protection de chacune ?
> - Dire ce qu'est un cookie de session ?

PHASE 4 · JOURS 23 À 30

Systèmes, défense et suite

OBJECTIF

Comprendre les mots de passe et la cryptographie, découvrir l'élévation de privilèges, apprendre à penser en défenseur, rédiger un rapport et bâtir ton plan pour la suite.

Jour 23 — Mots de passe et hachage

Théorie — Cours, chapitre 16. Hachage vs chiffrement, sel, pourquoi MD5 et SHA-1 sont dépassés pour les mots de passe, bcrypt/Argon2, attaques par dictionnaire.

Pratique — Dans Termux :

```
echo -n "bonjour" | sha256sum
echo -n "Bonjour" | sha256sum
```

Compare les deux résultats. Puis installe un gestionnaire de mots de passe et active la double authentification sur tes comptes importants.

Validation — Pourquoi un seul caractère changé donne-t-il une empreinte totalement différente ?

Jour 24 — Bases de la cryptographie

Théorie — Cours, chapitre 17. Chiffrement symétrique / asymétrique, clés publiques et privées, encodage ≠ chiffrement (Base64).

Pratique — Dans Termux : `echo "hacker" | base64` puis décode le résultat avec `base64 -d`. Génère une paire de clés SSH avec

`ssh-keygen` et observe les deux fichiers créés.

Validation — Pourquoi Base64 n'est-il **pas** une protection ?

Jour 25 — Élévation de privilèges sous Linux

Théorie — Cours, chapitre 18. Ce qu'est un privilège, les erreurs de configuration classiques (droits sudo trop larges, fichiers SUID, mots de passe en clair).

Pratique — Bandit jusqu'au niveau 15, ou une salle TryHackMe débutant sur les privilèges Linux.

Validation — Donne trois erreurs de configuration qui permettent à un utilisateur de devenir root.

Jour 26 — Penser en défenseur (Blue Team)

Théorie — Cours, chapitre 19. Journaux (logs), pare-feu, mises à jour, principe du moindre privilège, défense en profondeur.

Pratique — Dans Termux, lis un fichier journal ou l'historique de tes commandes (`history`). Pour chaque attaque vue ce mois-ci, écris dans ton journal **comment on l'aurait détectée**.

Validation — Qu'est-ce que la défense en profondeur ? Donne une image concrète.

Jour 27 — Ingénierie sociale et hameçonnage

Théorie — Cours, chapitre 20. Phishing, prétexte, urgence artificielle, comment reconnaître un message piège.

Pratique — Analyse 3 e-mails ou SMS suspects que tu as reçus (sans cliquer !). Liste les indices.

Validation — Cite 5 signes qui doivent t'alerter dans un message.

Jour 28 — Ton premier mini-CTF

Pratique — Sur picoCTF (catégorie débutant / *General Skills*), résous au moins 3 défis. Ou une salle TryHackMe de type « room débutant » complète.

> **ASTUCE TÉLÉPHONE**
>
> Bloquer fait partie de l'apprentissage. Si tu sèches plus de 30 minutes sur un défi, lis un indice, pas la solution complète. Note dans ton journal ce que tu n'avais pas vu.

Jour 29 — Rédiger un rapport

Théorie — Cours, chapitre 21. Structure d'un rapport, niveaux de gravité, recommandations.

Pratique — Rédige un rapport de 2 pages sur l'audit de ton propre réseau Wi-Fi (jour 13) en suivant le modèle du cours.

Validation — Ton rapport est-il compréhensible par quelqu'un de non technique ?

Jour 30 — Bilan et plan pour la suite

Pratique — Relis tout ton journal. Refais les quatre auto-évaluations de fin de semaine.

Théorie — Cours, chapitre 22 : certifications, parcours de 6 mois, communautés, construire un portfolio.

> **OBJECTIF**
>
> Écris ton engagement pour les 90 prochains jours : quelle plateforme, combien d'heures par semaine, quel objectif concret (par exemple : terminer un parcours débutant TryHackMe complet, 30 labs PortSwigger, ou Bandit en entier).

Suivi de progression

Coche chaque jour terminé. Note ta confiance de 1 (perdu) à 5 (je pourrais l'expliquer à quelqu'un).

Jour	Thème	Fait	Confiance /5
1	Hacking éthique	☐	…
2	Loi et éthique	☐	…
3	Laboratoire Termux	☐	…
4	Navigation Linux	☐	…
5	grep, find, pipes	☐	…
6	Permissions	☐	…
7	Bilan 1	☐	…
8	OSI / TCP-IP	☐	…
9	Adressage IP	☐	…
10	Ports, TCP, UDP	☐	…
11	DNS, HTTP, HTTPS	☐	…
12	Nmap	☐	…
13	Wi-Fi	☐	…
14	Bilan 2	☐	…
15	Méthodologie	☐	…
16	OSINT	☐	…
17	Applications web	☐	…
18	OWASP Top 10	☐	…
19	Injection SQL	☐	…
20	XSS	☐	…
21	Contrôle d'accès	☐	…

Jour	Thème	Fait	Confiance /5
22	Bilan 3	☐	…
23	Mots de passe	☐	…
24	Cryptographie	☐	…
25	Privilèges Linux	☐	…
26	Blue Team	☐	…
27	Ingénierie sociale	☐	…
28	Mini-CTF	☐	…
29	Rapport	☐	…
30	Bilan final	☐	…

Gagner en assurance : les 5 conseils qui changent tout

1. **Compare-toi à toi d'hier, pas aux autres.** Les « experts » que tu vois en ligne ont des années d'avance. Ton journal est ta seule vraie mesure.
2. **Explique à voix haute.** Si tu peux expliquer une notion à quelqu'un, tu la maîtrises. Sinon, tu sais exactement quoi revoir.
3. **Le blocage est normal.** Tous les professionnels passent leur temps à chercher, se tromper et recommencer. Être bloqué, c'est apprendre.
4. **Rejoins une communauté.** Les Discord de TryHackMe ou de picoCTF accueillent les débutants. Poser une question n'a rien de honteux.
5. **Reste du bon côté.** Ta réputation est ton capital. Dans ce métier, un seul acte illégal peut fermer définitivement toutes les portes.